教学设计方案 S03:微服务架构总览与网关信任链

学习领域 LF2 | 第 3 周 | 授课教师版 | 180 分钟

1. 教学目标(布鲁姆分层)

- [解] 解释零信任:服务为何只信网关注入的头
- [应] 复现 403→带头→200 的信任链实验
- [析] 诊断'直连 403'到底是 bug 还是安全设计

2. 教学重难点

- 重点:诊断'直连 403'到底是 bug 还是安全设计
- 难点:复现 403→带头→200 的信任链实验
- 突破策略:情境导入(真实事故/需求)→知识建构精讲→真仓实训→检查互证→费曼外化

3. 教学准备

- 教学集群可用性预检(教师课前 30min);任务单打印/电子发牌;
- 情境素材核对:以 PLPP 最新 PROGRESS 阶段刷新本课情境(同步脚本拉取 project-references/)。

4. 180 分钟流程

环节	时长	教师动作	学生活动	观测点
A 情境导入	20'	讲情境、发任务单	领会工单、明确目标	能复述本课目标
B 计划	10'	巡视,不代拆	组内拆解分工	计划可执行
C 决策	5'	把关安全红线	30 秒方案陈述	红线重申到位
D 理论精讲	35'	按'知识建构要点'爬梯,层层提问	答+记笔记+追问	每层有应答
E 实施	70'	双师巡回,只提问不代写	真仓实操、记工单	步骤推进与证据留存
F 检查	15'	抽查	检查员勾验+互查	清单全过

环节	时长	教师动作	学生活动	观测点
G 评价+费曼	25'	评分点回收; 费曼只提问	费曼员上台	外行能懂

5. 理论精讲提纲(35min)

1) 网关在微服务里的角色

- nginx-gateway 统一入口:路由/鉴权/限流/注入身份头
- 上游服务不直接解析 JWT,而信任网关注入的 X-User-* 头

2) 信任链与零信任

- HeaderAuthFilter 只信 X-Gateway-Verified=1(网关注入)
- 直连 NodePort 没有该头→403——这是设计,不是故障
- 推论:任何'带头就 200'的实验都在证明信任链在工作

3) NodePort 直连 vs 网关路径

- NodePort:31826(iam)/31965(tenant)/31429(course) 调试通道
- 生产路径:经网关(带校验头)——两条路径的语义不同
- 调试纪律:测试结论必须注明'走了哪条路径'

6. 实训指导(70min)

1. **1. 复现 403**:不带 X-Gateway-Verified 直接 curl tenant 学分规则创建接口 → 403
2. **2. 带头对比**:补 X-Gateway-Verified:1 + X-User-Roles:ROLE_SUPER_ADMIN → 200
3. **3. 写实验报告**:记录两组请求/响应,结论:403=安全设计;规则创建无 DomainEvent 为遗留
4. **4. 反向测试**:带头但角色为 ROLE_STUDENT → 应 403(授权仍然生效)

7. 布鲁姆提问设计(课堂穿插)

- [解] 为什么…而不是…?(解释零信任:服务为何只信网关注入的头…)
- [应] 现场演示…(复现 403→带头→200 的信任链实验…)
- [析] 如果…坏了,断在哪一跳?(诊断'直连 403'到底是 bug 还是安全设计…)

8. 费曼讲题与引导

讲题:给外行讲'为什么公司前台不让陌生人直接进办公室,但你带着工牌还得刷卡'类比信任链。 追问链:还有吗?→换个说法?→如果外行问…你怎么答?→一句话压缩?

9. 评价与作业

评分点:三组实验证据(50%)+报告结论准确(30%)+反向测试(20%) 作业:

- 费曼卡#3:零信任一句话+类比图
- 实验报告补第 4 组反向测试证据

10. 板书设计

左板:本课目标(三层) | 中板:核心流程图(随精讲生长) | 右板:实训进度墙(各组勾验状态)